

Threat Hunting



Modul SOC.H2501

Inhalt

- Was ist Threat Hunting?
- Gegenüberstellung
- Weshalb Threat Hunting
- Vorteile durch Einsatz von Threat Hunting
- Threat Hunting Strategie und Prozess(e)
- Vorgehensweisen & Hypothesen
- Threat Hunting Basics
- Techniken, Checklisten, Tools, ...

Was ist Threat Hunting

- Threat Hunting, auch als **Cyber Threat Hunting** bezeichnet, ist eine **proaktive Methode** zur Verbesserung der Cyber Security.
- Sie sucht und Identifiziert in Netzwerken und IT-Systemen **präventiv** nach potenziellen und nicht behobenen Bedrohungen.
- Der Prozess des Threat Huntings ist gekennzeichnet durch **manuelle Tätigkeiten** unterstützt von **automatisierten Techniken** und Tools.

Gegenüberstellung



- **Incident Response** → **reaktiv**

reagiert auf Alarme und bringt die Organisation in einen sicheren Zustand zurück



- **Forensics** → **investigativ**

Dokumentiert historische Ereignisse: Was passierte?
Wann? Wo? Wenn?



- **Threat Hunting** → **proaktiv**

Identifiziert wie sich Bedrohungen in einer IT-Umgebung verhalten. Gesteuert durch eine Hypothese
– ohne Incident oder Ereignis



Weshalb Threat Hunting (1)

- Threat Hunting ist wichtig, weil komplexe Bedrohungen in der Lage sind, automatisierte Cybersicherheitsschranken zu überwinden.
- Obwohl automatisierte Sicherheitstools und Tier-1- und Tier-2-Analysten im Security Operations Center (SOC) meist in der Lage sind, ca. 80% der Bedrohungen in den Griff zu bekommen, bleiben noch die restlichen 20%, die Sorgen bereiten. Bei diesen übrigen 20% der Bedrohungen handelt es sich häufig um hochkomplexe Bedrohungen, die erheblichen Schaden anrichten können.
- Verfügen die Angreifer über ausreichend Zeit und Ressourcen, können sie in jedes Netzwerk eindringen und dort teilweise mehrere hundert Tage lang unentdeckt bleiben. (→ "dwell time")
- Wirksames Threat Hunting verkürzt den Zeitraum zwischen Eindringen und Aufdecken und kann so den Schaden durch Angreifer verringern.

Quelle: <https://www.ibm.com/de-de/topics/threat-hunting>



Weshalb Threat Hunting (2)

- Angreifer lauern oft wochen- oder sogar monatelang, bevor sie entdeckt werden. Sie warten geduldig, um Daten abzuschöpfen und vertrauliche Informationen und Zugangsdaten zu finden, die ihnen weitere Zugriffe ermöglichen.
- Dies schafft die Voraussetzungen für massive Datensicherheitsverletzungen.
- Welchen Schaden können potenzielle Bedrohungen anrichten? Dem "Bericht über die Kosten einer Datenschutzverletzung im 2025" (<https://www.ibm.com/de-de/reports/data-breach>) zufolge, kostet eine Datenschutzverletzung ein Unternehmen im Durchschnitt rund 4 Millionen USD. Dabei können die schädlichen Auswirkungen einer Datenpanne noch jahrelang Auswirkungen haben.
- Je länger die Zeitspanne zwischen dem Ausfall eines Systems und der Reaktion darauf, desto teurer kann es für ein Unternehmen werden.

Quelle: <https://www.ibm.com/de-de/topics/threat-hunting>

Vorteile durch Einsatz von Threat Hunting

Der Einsatz des präventiven Threat Huntings bietet unter anderem folgende Vorteile:

- Angreifer können sich nicht längere Zeit unbemerkt in der IT-Umgebung bewegen
- schnellere Erkennung von potenziellen Bedrohungen, ohne dass ein konkretes Sicherheitsereignis vorliegen muss
- Minimierung der Folgen von Sicherheitsverletzungen
- Aufdeckung von gefährlichem Benutzerverhalten
- Optimierung der automatisierten Sicherheitssysteme mit Hilfe der Erkenntnisse des Threat Huntings
- Verringerung der potenziellen Angriffsfläche und Reduzierung der Risiken für die Cyber Security

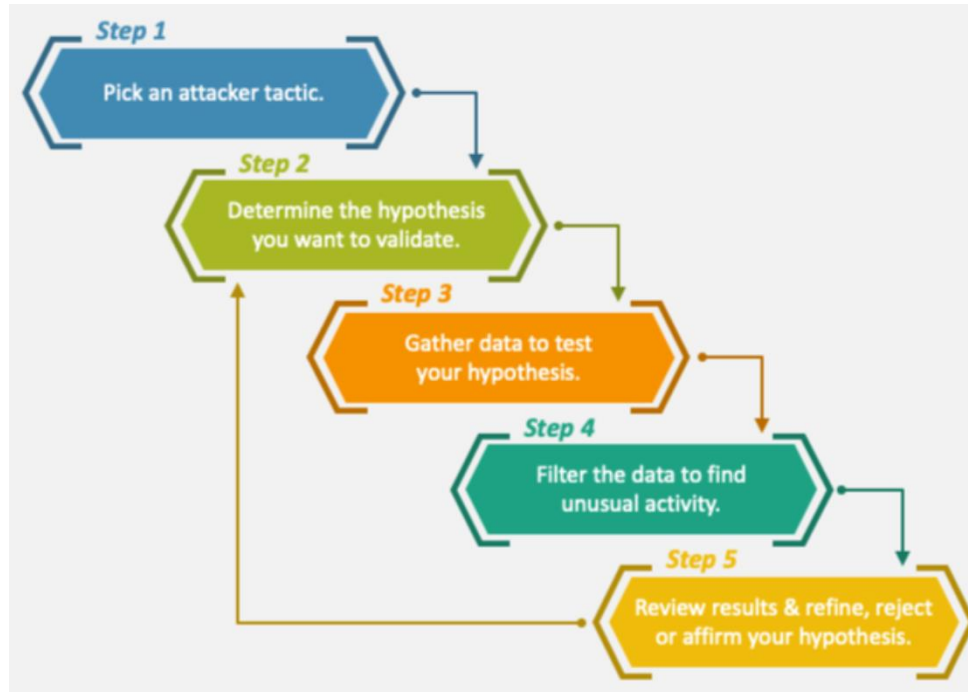


Cyber Threat Hunting "Ökosystem"



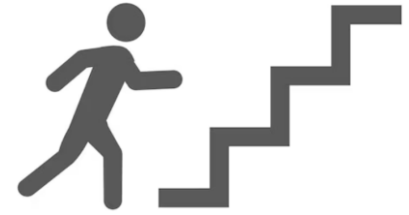
Threat Hunting Prozess (1)

Der Threat Hunting Prozess kann folgendermassen ablaufen:



Threat Hunting Prozess (2)



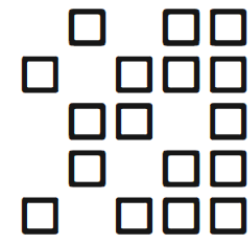


Verschiedene Vorgehensweisen

Arten des Threat Hunting

- Die Bedrohungssucher beginnen ihre Arbeit meist mit einer **Hypothese** auf der Grundlage von Sicherheitsdaten oder einem Auslöser → z.B. Meldung NCSC* !
- Die Hypothese oder der Auslöser dienen als Sprungbrett für eine eingehendere Untersuchung der potenziellen Risiken. Bei diesen vertieften Untersuchungen handelt es sich um **strukturierte**, **unstrukturierte** oder **situative** Suchen.

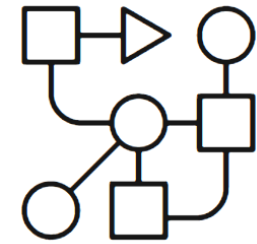
*Quelle: <https://www.ncsc.admin.ch/ncsc/de/home/aktuell/aktuelle-vorfaelle.html>



Vorgehen - Strukturierte Suche

- Eine strukturierte Suche erfolgt auf der Grundlage eines Angriffsindikators (IoA) und der Taktiken, Techniken und Verfahren (TTP) eines Angreifers.
- Alle Suchen erfolgen entsprechend abgestimmt auf die TTPs der Bedrohungsakteure. Daher kann der Sucher in der Regel einen Bedrohungsakteur identifizieren, noch bevor der Angreifer Schaden in der Umgebung anrichten kann.
- Bei dieser Suche kommt das MITRE ATT&CK-Framework zum Einsatz.

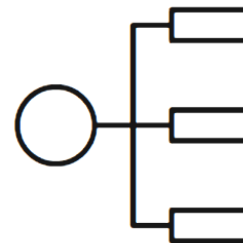
Quelle: <https://attack.mitre.org/>



Vorgehen - Unstrukturierte Suche

- Eine unstrukturierte Suche wird auf der Grundlage eines Auslösers eingeleitet – einer von vielen Kompromittierungs-Indikatoren (Indicators of Compromise, IoC).
- Dieser Auslöser veranlasst einen Sucher häufig, nach Mustern vor und nach der Feststellung einer Abweichung zu suchen.
- Der Sucher kann so weit zurück recherchieren, wie Vorratsdatenspeicherung und bereits früher zugeordnete Verstöße dies zulassen.

Vorgehen - Situations- oder entitätsbezogene Suche



- Eine Situationshypothese ergibt sich aus der internen Risikobewertung eines Unternehmens oder einer Analyse der Trends und Schwachstellen seiner IT-Umgebung.
- Entitätsorientierte Hinweise stammen aus Angriffsdaten, die mittels Crowdsourcing zusammengetragen werden und die neuesten TTPs aktueller Cyberbedrohungen offenlegen können.
- Ein Bedrohungssucher kann dann nach diesen spezifischen Verhaltensweisen in der Umgebung suchen.



Threat Hunting Hypothese (1)

- Eine Threat Hunting-Hypothese ist eine fundierte Annahme über einen Cyberangriff oder eine seiner Komponenten. Wie in der wissenschaftlichen Forschung bilden auch bei der hypothesengesteuerten Bedrohungsjagd die Hypothesen die Grundlage der Untersuchungen.
- Sobald eine Hypothese aufgestellt ist, muss ein Threat-Hunter Schritte unternehmen, um sie zu testen. Die Strategie zum Testen der Hypothese macht den grössten Teil der Arbeit bei der Bedrohungsjagd aus (z. B. dauert die Erstellung einer sinnvollen Abfrage oft länger als ihre Ausführung). Dazu gehört häufig die Identifizierung verwandter Datenquellen (Sicherheitsereignisse, Systemprotokolle usw.), relevante Analysetechniken (Abfragen, Stack-Counting usw.) und dann die Umsetzung dieser Strategie.



Threat Hunting Hypothese (2)

- Die Hypothese der Bedrohungsjagd erleichtert eine proaktive Cyber-Verteidigungsroutine. Eine der vielen Varianten der letzteren besteht aus:
 - **Vorhersage des Verhaltens** des Gegners
 - **Vorschlagen von Möglichkeiten**, eine Bedrohung zu finden
 - **Erkennung von Anomalien**, Eindringlingen, Überschreitungen der Basislinie/Schwellenwerte
 - Untersuchung von **Ereigniskorrelationen**
 - Testen von **Proben in Sandboxes**, Honey Pots und emulierten Umgebungen
 - **Dokumentieren** der Ergebnisse
 - **Verbesserung des Schutzes** von Anlagen und Infrastruktur
 - Durchführen von **Schadensbegrenzung** Informieren der Behörden (falls zutreffend)
 - Insgesamt hängt der Erfolg der Bedrohungsjagd in hohem Masse von einer **aufschlussreichen Hypothese** ab!

Threat Hunting Hypothese (3)

Wie erstellt man eine Hypothese für eine Bedrohungsjagd?

- Um den Anfang zu erleichtern, kann man sich die Hypothesen für die Bedrohungsjagd als eine Art Benutzer geschichten vorstellen, allerdings aus der Perspektive der Malware.

- “
- *As a [malicious script], I want to [send a request via TCP port 50050] so I can [establish connection].*
 - *As an [infected zip], I want to [use WMI] so I can [maintain persistence].*
 - *As a [Javascript code], I want to [exploit BITSAdmin] so I can [download modules].*

- “
- Malware X:*
- Executes a command via EXE file*
 - Imports and executes PowerShell cmdlets from an external source*
 - Runs a local .NET binary*
 - Uses setenv() function to add the variable to the environment*

- “
- As an APT37 (North Korea), I want to attack the US government for political reasons, so I'll use Cobalt Strike in T1218.011, planting rundll32 for proxy execution of malicious code.*

Fortgeschrittene Threat Hunting Hypothesen

- Die Hypothesen zur Bedrohungsjagd können operativ sein, wie in den vorherigen Beispielen, oder taktisch und strategisch.
- Erfahrene Bedrohungsjäger können umfassendere Hypothesen formulieren, die dennoch zu gezielten Tests führen können. Dazu muss man folgende Voraussetzungen erfüllen:
 - **Fachwissen:** Erfahrung, Austausch von Wissen
 - **Situationsbewusstsein:** Kenntnis der internen Infrastruktur, der Schwachstellen und der wichtigsten Vermögenswerte
 - **Threat Intelligenz:** Daten über Bedrohungen wie IOCs und TTPs abrufen
- Man wendet alle oben genannten Faktoren an, um eine tiefgreifende analytische Hypothese darüber zu formulieren, auf welche Systeme Angreifer abzielen und was sie zu erreichen versuchen werden.

Threat Hunting Hypothesen Beispiele

Weiter Beispiele für realistische und praxisnahe Threat Hunting Hypothesen:

- <https://www.socinvestigation.com/threat-hunting-hypothesis-examples-start-for-a-good-hunt/>
- <https://www.cyborgsecurity.com/blog/50-threat-hunting-hypothesis-examples/>
- <https://www.youtube.com/watch?v=ArK8sqDGYVI&t=193s>

Threat Hunting Basics



- **Daten**

Logdaten für die Analyse, die oft von einzelnen Geräten gesammelt und von einem System zentralisiert werden



- **Baseline**

Einfache Metriken und etablierte, sichere Konfigurationen oder Verhalten



- **Cyber Threat Intelligence**

Sammlung von Daten über bekannte Bedrohungen und Bedrohungsakteure

Schlüsselkomponenten fürs Threat Hunting



- Qualität der gesammelten Daten

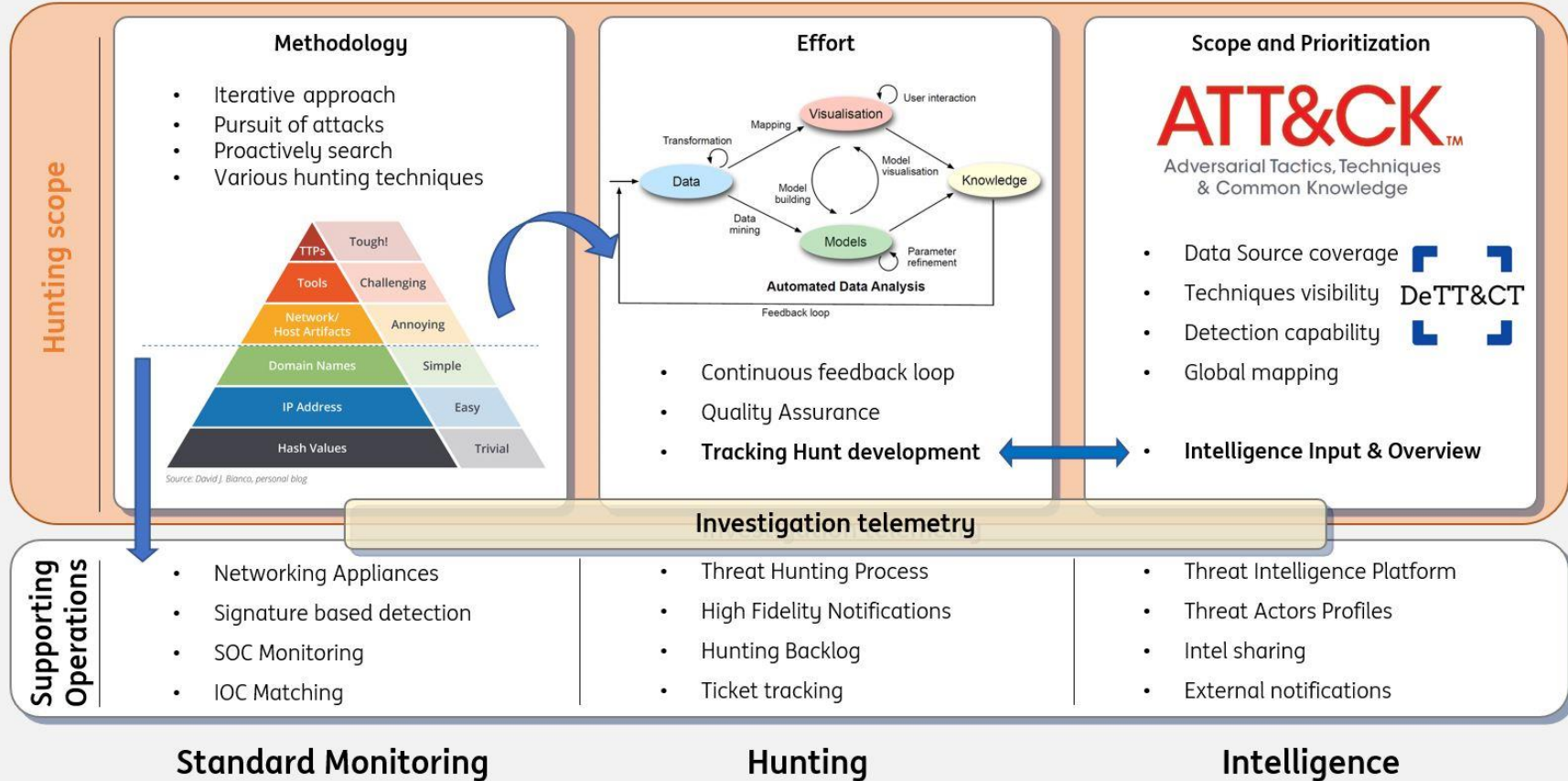


- Tools und Hilfsmittel fürs Sammeln und fürs Analysieren der Daten



- Threat Hunter Skills

Threat Hunting Core



Source: Renato Fontana

Techniken, Checklisten, ...

Checkliste:

- <https://www.devo.com/blog/effective-threat-hunting-tools-checklist/>

Eine gute Übersicht bietet:

- <https://proinf.com/threat-hunting-techniques-checklist-examples-process-exection-metrics>
- Awesome Threat Detection and Hunting
(<https://github.com/0x4D31/awesome-threat-detection>)

Tools, ...

- **SIEM:**

Splunk Enterprise Security, ELK, graylog, LogRhythm, Azure Sentinel (Cloud), Rapid7, IBM QRadar, FireEye

- **NDR, EDR, xDR:**

CrowdStrike Falcon Overwatch, VMWare Carbon Black Endpoint, ManageEngine Vulnerability Manager Plus, IBMX-Force Exchange, Trend Micro XDR, CheckPoint SpectralOps (Cloud), Vectra AI

- **Windows & Linux:**

AI Engine, APT-Hunter, DeepBlue CLI, Automater, CyberChef, Velociraptor, DNSTwist, Phishing Catcher, AttackerKB, YARA, TEEK, Suricata, Snort, Autopsy,

- **Sandboxes:**

Cuckoo Sandbox, Sandbox_Scryer, ANY.RUN, Hybrid Analysis



Aufgabe

- Sich eine Hypothese überlegen
 - Beispiele anschauen und versuchen eines davon zu adaptieren
- Auf dem Windows/Splunk System versuchen
 1. Angreifer zu spielen und Hypothese zu realisieren
 2. Threat Hunter spielen und versuchen den Angriff zu detektieren und zu belegen